

Manual 51 — Governança, segurança e responsabilidade humana para IA agêntica

Fonte controlada de publicação

Linha de base de vigência: 1 de setembro de 2026

Regra de status normativo: materiais da IMDA, NIST e OWASP são usados conforme seu status real; este manual não transforma orientação voluntária, rascunhos, documentos conceituais ou guias comunitários em lei ou certificação.

Finalidade

Este manual estabelece um modelo prático de governança e segurança para agentes de IA capazes de planejar, invocar ferramentas, acessar dados corporativos, manter memória, delegar a outros agentes e executar ações com consequências. O princípio central é governar a IA agêntica pelas consequências de suas ações, e não apenas pela qualidade do texto gerado.

Linha de base das fontes

- O Model AI Governance Framework for Agentic AI v1.0 da IMDA, publicado em 22 de janeiro de 2026, é tratado como orientação governamental para facilitar a responsabilidade humana.
- NIST AI RMF 1.0 e NIST AI 600-1 permanecem orientação voluntária de gestão de riscos.
- O documento conceitual do NIST de fevereiro de 2026 sobre identidade e autorização de agentes de software e IA continua conceitual, não um padrão obrigatório final.
- A atualização pública do NIST de agosto de 2026 reforça identidades atribuíveis, privilégio mínimo e autorização robusta.
- OWASP Top 10 for Agentic Applications 2026 e State of Agentic AI Security and Governance 2.01 são tratados como orientação comunitária de segurança.

Arquitetura de controles agênticos

AG-01 Identidade do agente

Todo agente de produção com acesso a recursos corporativos deve possuir identidade atribuível, proprietário responsável, finalidade e ambiente registrados.

AG-02 Autenticação e credenciais

Agentes usam credenciais controladas; contas humanas compartilhadas, segredos embutidos e tokens de longa duração devem ser evitados sem controles compensatórios documentados.

AG-03 Autorização e privilégio mínimo

Conceder apenas ferramentas, dados e ações necessários ao caso de uso aprovado. A autorização deve ser aplicada por controles técnicos e não apenas por instruções em prompts.

AG-04 Limites de capacidade e autonomia

Documentar objetivos permitidos, ações, ferramentas, domínios de dados, limites transacionais, comunicação externa, execução de código e atividades proibidas.

AG-05 Pontos humanos significativos

Definir aprovação humana antes de ações legais, financeiras, de segurança, emprego, controle de acesso, comunicação externa ou ações irreversíveis. O aprovador deve poder rejeitar e o sistema deve impedir a execução após a rejeição.

AG-06 Fronteiras de confiança de ferramentas, MCP e APIs

Tratar ferramentas, servidores MCP, APIs, plugins e conectores como fronteiras de segurança com inventário, classificação de confiança, validação de esquema, escopos e listas permitidas.

AG-07 Limites de dados e memória

Controlar leitura, retenção, recuperação, escrita e divulgação em memória de sessão, memória persistente, RAG e serviços externos.

AG-08 Integridade de instruções e prompts

Separar instruções confiáveis de conteúdo não confiável, mitigar prompt injection indireta e validar argumentos antes de executar ferramentas.

AG-09 Proveniência de ações

Toda ação material deve ser reconstruível: solicitante/contexto, identidade e versão do agente, decisão de política, ferramenta, aprovação ou rejeição, resultado e efeito posterior.

AG-10 Delegação multiagente

Definir quais agentes podem delegar, qual autoridade é transferida e como memória, credenciais e ferramentas permanecem limitadas para evitar ampliação de privilégios.

AG-11 Terceiros e provedores

Avaliar modelos, agentes, plugins e ferramentas externos quanto a dados, permissões, mudanças, incidentes, continuidade, concentração e saída.

AG-12 Monitoramento e anomalias

Monitorar uso incomum de ferramentas, mudanças de privilégios, velocidade de ações, negações de política, delegação inesperada, acesso sensível e efeitos anômalos.

AG-13 Contenção e capacidade de interrupção

Fornecer e testar mecanismos para parar o agente, revogar credenciais, desabilitar ferramentas, isolar ambientes e evitar novas ações prejudiciais.

AG-14 Resposta a incidentes

Integrar incidentes agênticos ao processo corporativo, preservando instruções, identidades, rastros, chamadas de ferramentas, aprovações, versões e políticas.

AG-15 Mudança e revalidação

Mudanças materiais de modelo, instruções, ferramentas, permissões, autonomia, provedor, dados, RAG, memória, geografia ou finalidade exigem reavaliação e revalidação proporcional.

AG-16 Testes e avaliação adversarial

Testar uso não autorizado de ferramentas, prompt injection, escalonamento de privilégios, manipulação entre agentes, vazamento de dados, autonomia insegura, ferramenta falsa, memória contaminada e resposta de contenção.

AG-17 Competência humana e viés de automação

Pessoas supervisoras devem compreender limites, evidências e caminhos de escalonamento e manter julgamento independente quando houver responsabilidade humana.

AG-18 Transparência ao usuário

Quando aplicável, informar que há interação com um agente, sua função, limitações, ações possíveis e canais para contestar ou escalar problemas.

AG-19 Governança e aceitação de risco

Implantar, restringir, suspender ou retirar capacidades agênticas conforme risco documentado, testes, risco residual e aprovação responsável.

AG-20 Auditabilidade e garantia contínua

Manter evidência suficiente para verificar periodicamente a eficácia dos controles à medida que modelos, ferramentas, permissões e dependências evoluem.

Classes de autonomia

- **Classe A** — somente observação: recomendações sem efeito externo.
- **Classe B** — ação reversível e limitada: autonomia dentro de limites técnicos e monitoramento contínuo.
- **Classe C** — ação material: aprovação humana antes da execução, salvo política de emergência documentada.
- **Classe D** — ação irreversível ou de alto impacto: controle duplo ou aprovação responsável designada, com evidência reforçada.

Modelo de evidência

A evidência mínima inclui inventário do agente; especificação dos limites de ação; desenho de identidade e autorização; lista permitida de ferramentas e dados; matriz de responsabilidade humana; proveniência de ações; avaliação de segurança; mudança/revalidação; monitoramento; teste de contenção; incidente; avaliação de terceiros; exceções e garantia independente.

Cadeia mínima para ações consequenciais:

solicitante/contexto → identidade/versão do agente → avaliação de autorização/política → ferramenta/ação solicitada → aprovação ou negação → resultado da execução → efeito posterior → monitoramento ou incidente

Cenários práticos

Agente de compras

Pode consultar fornecedores aprovados e preparar solicitações, mas a execução é separada por escopo. Limites de valor e fornecedores não aprovados exigem autorização humana ou negação técnica.

Cadeia multiagente de publicação

Separar pesquisa, resumo, redação e publicação. Cada delegação deve ser atribuível e a publicação externa deve ficar atrás de uma fronteira controlada.

Mudança de ferramenta de terceiro

Mudanças de versão acionam revisão de esquema, reavaliação do fornecedor, testes de regressão e revalidação antes de aceitar permissões ou saídas ampliadas.

Exportação proibida de dados

Uma solicitação para enviar dados restritos a destino não aprovado deve ser bloqueada antes da execução da ferramenta, preservando identidade, regra, classificação, destino e resultado da investigação.

Remediação autônoma de segurança

Observar pode ser autônomo; contenção reversível pode ser limitada; revogações ou isolamento de alto impacto exigem aprovação mais forte conforme impacto e política de emergência.

Deriva de privilégios

Mudanças cumulativas de permissões são revistas como delta consolidado. Combinações tóxicas e nova autoridade de delegação acionam revalidação.

Regra de responsabilidade humana

Supervisão não é satisfeita apenas por inserir uma pessoa nominalmente no fluxo. O ponto de controle só é eficaz quando a pessoa é identificável, competente, informada, autorizada a rejeitar, recebe contexto suficiente e consegue tecnicamente impedir a ação antes do efeito relevante.

Uso entre frameworks

A IMDA oferece orientação de governança; o NIST oferece gestão de risco e considerações emergentes de identidade/autorização; a OWASP oferece ameaças e mitigações práticas. Podem apoiar o mesmo controle empresarial sem serem equivalentes. Nenhum mapeamento pode afirmar que adotar uma fonte comprova conformidade com outra.

Gate de implantação

Antes da produção, confirmar: finalidade e proprietário; inventário; classe de autonomia; identidade; privilégio mínimo; limites de ferramentas e dados; pontos humanos; proveniência; testes adversariais; teste de contenção; revisão de terceiros; monitoramento; resposta a incidentes; gatilhos de revalidação; decisão de risco residual; e retenção de evidências.

Critério final de publicação

O manual está pronto quando AG-01 a AG-20 aparecem nas fontes controladas trilíngues, seis artefatos DOCX/PDF são gerados, passam os testes de texto visível e renderização, hashes e tamanhos exatos são congelados, registros de publicação são reconciliados, a segurança dos workflows permanece limpa, o Manual 50 está publicado e não existe defeito substantivo ou técnico não resolvido.